SafetySense
CALLS FOR HELP WHEN YOU CAN'T

ATTACHMENT 5 OF 5 · SECURITY & PRIVACY

Listens only when asked. Keeps nothing unless something's wrong.

SafetySense handles some of the most sensitive data a student has: where they are, what's happening around them, and possibly evidence of an assault. This document lists every piece of data we hold, how it's protected, the threats we designed for, and the limits we haven't solved yet.

Scope **iOS app · Supabase backend · Twilio · Noonlight · Vercel**
Build **contest prototype, Nov 2026**

01 Design principles

On-device first
Sound classification, speech recognition and the AI second opinion all run on the iPhone. None of them has a server path.

Nothing saved by default
While guarding, audio exists only in a 30-second RAM buffer that's constantly overwritten. Nothing is written to disk.

Server sees the minimum
The server gets a heartbeat and contact details. Evidence reaches it only as ciphertext, and it never holds the key.

No trackers
No third-party iOS SDKs at all: no analytics, ads or crash reporters. Data is never sold or shared for marketing.

02 Data inventory

DATA	WHERE IT LIVES	RETENTION	PROTECTION
Live audio while guarding	iPhone RAM only (30 s ring buffer)	Overwritten continuously and gone when the session ends	Never written to disk and never transmitted
Sound labels, transcripts, AI reasoning	iPhone memory	Discarded after scoring	Processed by on-device models. Never logged, never sent
Evidence audio (after an Alert)	iPhone Vault, plus a copy in the private Supabase Storage bucket	Device: user's setting (30 days by default). Server: **deleted after 30 days** by an hourly job, or at once on "Delete everything"	AES-256-GCM per 15 s chunk. Key in the Keychain, this device only. SHA-256 per chunk. Alert ID and sequence number bound as authenticated data. iOS file protection
Safety PIN, duress PIN, safe word	iPhone Keychain	Until changed or erased	PINs stored only as salted SHA-256 hashes. Never sent to the server
Responder profile (description, medical notes)	iPhone only	Until the user deletes it	Complete file protection. Not sent anywhere in the current build

DATA	WHERE IT LIVES	RETENTION	PROTECTION
Account: name, phone, campus	Postgres `devices`	Until "Delete everything" (server route `account/delete`)	Row-level security with no policies (service role only)
Device credential	Phone Keychain; server keeps a SHA-256	Until re-registration	The secret is shown once and compared in constant time
Trusted contacts (name, phone)	iPhone and Postgres `contacts`	Replaced on every edit; cascade delete	At most 5, US numbers only. Used only to call and text during an alert
Session status, last location, battery	Postgres `sessions`	Ended sessions deleted after 90 days	Written only while a Guard session is on
Location history	Postgres `locations`	**Deleted after 30 days** by an hourly job	Recorded only during a session or alert
Sealed date details	Postgres `sessions`	Cleared 48 h after the session starts	AES-256-GCM with a key in Supabase Vault. Shown to contacts only while an alert is active
Alert timeline and share token	Postgres `alerts`, `events`	Link dies 2 h after cancel, 48 h maximum. Alerts and timelines deleted after 90 days (test alerts after 48 h)	A 192-bit random token. The page is `noindex`, `no-referrer` and `no-store`
Data held by third parties	Twilio, Noonlight, Vercel	Under each provider's policy	Twilio: contact numbers, first name, alert reason. Noonlight (Level 3 only): name, phone, location. Vercel: standard access logs

03 How the protections work

RAM-ONLY BUFFER

A fixed-size `PCMRingBuffer` of mono samples is overwritten in place. When the ladder reaches Alert, those 30 seconds and the live audio after them are encrypted the moment they're captured. Below Alert, nothing is persisted.

EVIDENCE VAULT

CryptoKit AES-GCM with a 256-bit key generated on the device (`kSecAttrAccessibleAfterFirstUnlockThisDeviceOnly`). Each chunk's SHA-256 is shown in the Vault and stored with the upload, so tampering is detectable. A swapped or reordered chunk fails to decrypt because the alert ID and sequence number are bound in. Chunks upload *while recording*, so evidence survives a smashed phone. The Vault opens only with Face ID or the passcode, and sharing it with an advocate or police is always the user's choice.

SERVER LOCKDOWN

Every table has RLS enabled with no policies, and `anon` and `authenticated` have no grants. Only the edge function's service role touches data, so the public key alone reads nothing. Secrets live in Supabase Vault and are read through a `SECURITY DEFINER` function that only the service role can run. The cron job reads its secret from Vault at run time, so it never appears in the job table.

AUTHENTICATION

Device routes need the device ID and secret, checked against a stored hash in constant time. Share routes are scoped to one alert's token. Twilio callbacks must carry a valid `X-Twilio-Signature` (HMAC-SHA1), and the watchdog requires a secret header. Admin setup is hash-gated and switched off.

ABUSE LIMITS	At most 6 live alerts per device per hour, 5 contacts, and US numbers only. One live alert per session, so repeat requests reuse it. A practice drill runs as a dry run and is labelled **TEST**, and dry runs never call Twilio.
DURESS PIN	Duress is checked before the real PIN, so it can never count as a valid cancel. The phone shows "cancelled" and the API answers `{status:"cancelled"}`, but the server silently escalates and keeps the alert live for contacts. `alert/status` hides the dispatch from the phone, so someone looking over the user's shoulder sees nothing unusual. Open item: the prototype doesn't yet tell the monitoring center that an alarm is a duress alarm, so a verification call could still reach the phone. Production needs a no-callback path. A wrong PIN never cancels.

04 Threat model

THREAT	SCENARIO	MITIGATIONS	WHAT'S LEFT
Abuser has the phone (or the passcode)	Forces the user to cancel, browses the app, or watches the screen.	Duress PIN, Face ID on the Vault and on ending a session, a discreet alternate app icon, and no audio history to browse.	Someone who knows the passcode can see the contacts and settings, or delete the app outside a session.
SafetySense used as stalkerware	A partner installs it to track someone, or adds themselves as a contact.	Location is shared only during a session or alert the phone's owner starts, the Live Activity is always visible, links expire, and there's no silent-tracking mode.	Planned: notify the user when contacts change, and ask contacts to confirm by text before their first alert.
False positives	A loud party, a playful "stop!", or a dropped phone.	A 45 s check-in before any alert, the laughter/cheering rule, an LLM that can only nudge the score, PIN cancel, contacts first by default, and Noonlight's verification call before dispatch.	Thresholds still need tuning on real recordings (see Attachment 3 metrics).
Phone destroyed or taken	Smashed, switched off, or put in airplane mode mid-assault.	The server watchdog raises an alert from the last known location, and evidence is uploaded during recording.	The evidence key never leaves the device, so a destroyed phone means uploaded ciphertext can't be decrypted (see §06).
Server breach	An attacker reads the database.	Minimal data, hashed device secrets, ciphertext-only evidence, and secrets in Vault.	An attacker with both the database *and* Vault could read sealed date details, contacts and recent locations.
Link forwarded or leaked	The SMS link reaches someone it shouldn't.	A 192-bit token, short expiry, no location once the alert is cancelled, `noindex` and `no-referrer`.	Anyone holding a live link sees location until it expires. The map loads OpenStreetMap tiles, which reveals the general area to the tile server.
API abuse	Scripts register devices to trigger spam calls.	Rate limits, including 5 sign-ups per network per hour (only a salted hash of the IP is kept), US-only numbers, a 5-contact cap, and Twilio's verified-number restriction on the trial account.	`register` still needs only the publishable key. App Attest is needed before public launch.

05 Legal and compliance posture

- **Recording consent (New Mexico).** NMSA 1978 § 30-12-1(C) prohibits intercepting telegraph or telephone communications "without the consent of a sender or intended recipient," which makes New Mexico a one-party-consent state for calls. The statute's text addresses telegraph and telephone communications, and how it applies to in-person audio captured by a phone is less clear. § 30-12-11 also gives a civil remedy for intercepted wire or oral communications. SafetySense lowers the risk by design: it records nothing until an Alert, the user is present at the conversation, and evidence is never shared automatically. (Statute text checked Nov 4, 2026; this is not legal advice.)
  `LEGAL REVIEW BEFORE LAUNCH`
- **HIPAA:** doesn't apply. SafetySense isn't a covered entity or business associate. Medical notes are entered by the user, stay on the device, and are still treated as sensitive.
- **FERPA:** doesn't apply. We don't receive education records from UNM or CNM. If a campus integration ever shares institutional data, we'd work under the institution's data-sharing agreement.
- **Title IX and Clery:** SafetySense never reports to a school or the police on its own. Reporting options are offered, never required, so the student stays in control. Any campus partnership would be reviewed with the Title IX offices for responsible-employee implications.
- **Breach response:** we'd follow New Mexico's Data Breach Notification Act (NMSA 1978 §§ 57-12C-1 to -12): notify affected users within 45 calendar days of discovery, and the Attorney General too if more than 1,000 New Mexicans are affected.
- **App Store:** privacy nutrition label "Data Linked to You" (contact info, location), no tracking, a purpose string for each permission, and permissions requested only when needed. The audience is 18 and over.
- **Emergency services:** SafetySense supplements 911 and never replaces it. The demo uses only the Noonlight sandbox or a clearly labelled simulated dispatch, never live 911.

06 Limitations we're stating plainly

- **Evidence key recovery.** The key is bound to the device, so if the phone is destroyed the server-side ciphertext can't be read. Planned fix: an optional recovery key the user stores themselves, or an escrow shared with an advocate the user picks.
- **Server-side deletion during a live alert.** "Delete everything" now calls `account/delete`, which removes the device's contacts, sessions, alerts, locations, events and encrypted evidence files and revokes its credentials at once. If a real alert is still live, those rows stay until it ends (48 h at most) so contacts keep their link, then the hourly job finishes the deletion. Deletion is best effort from the phone: if the phone is offline, the server copy expires on the retention schedule instead.
- **Sealed date details** are encrypted with a server-held key so the contact's browser can show them. A stronger design puts the key in the link's URL fragment so the server can never decrypt them.
- **PIN hashing** uses salted SHA-256 inside the Keychain. A 4-digit PIN would be brute-forceable if the Keychain were extracted, so we'll move to a slow KDF or a Secure Enclave–bound check.
- **Prototype accounts:** Twilio is on a trial account (US SMS is blocked by A2P 10DLC rules, and calls go only to verified numbers), Noonlight is sandbox-only, and the Noonlight alarm PIN is a fixed placeholder. None of these are production settings.
- **Not yet built:** App Attest, Sign in with Apple account recovery, contact opt-in confirmation, and an independent security review. All are needed before any public release.

OUR COMMITMENT

Before SafetySense goes to real students, we'll have an independent privacy and legal review, publish a plain-language privacy policy, and ask UNM's Information Security & Privacy Office and campus advocates to review the data flows in this document.